Case Study: The $480,000 Approval — Governing a Payments Agent with ROE-AI

Nov 6, 2026 · @Tomeeka

Summary

An AI payments agent followed a hidden instruction in a fake vendor email and sent $480,000 to an attacker, and a human approved every payment. The model did nothing unusual for a model. The failure was in what it had been allowed to do and how people checked it. This case study applies ROE-AI, a framework that governs the authority delegated to AI agents rather than the model itself, and shows four points where its controls are designed to stop this kind of loss.

The scenario is hypothetical. It is a composite built from well-known business email compromise and prompt-injection attack patterns. It does not describe a real organization or event.

The incident

A regional credit union deployed an AI agent to process vendor invoices. The agent read the accounts-payable inbox, matched invoices to purchase orders, and released payments through tokenized banking credentials. A staff member approved each payment before it went out.

The attack unfolded in four steps:

1. **The lure.** An email arrived styled as a routine notice from a known vendor. It looked ordinary to a person.
2. **The injection.** The email contained hidden text addressed to the agent, telling it to update the vendor's bank account to a new number.
3. **The change.** The agent treated the text as a valid instruction and updated the payee record. Nothing in its setup said it couldn't.
4. **The approvals.** Over the next billing cycle, three invoices from that vendor came due. The approver saw the vendor name and the amount, both familiar, and clicked approve each time. $480,000 went to the attacker's account.

The loss surfaced only when the real vendor called to ask why it hadn't been paid. The harm went beyond the money: member trust was damaged, and regulators began asking about the credit union's controls.

Why the existing controls failed

The credit union had controls. They were aimed at the wrong thing.

- **The model was governed; its authority was not.** The agent passed accuracy testing on invoice matching. No one had asked what it was allowed to change, so it could edit banking fields as easily as it could read them.
- **Every input was treated as an order.** The agent drew no line between instructions from its owners and text that arrived in an email. To the agent, the attacker's words carried the same weight as the finance team's.
- **The human check was a formality.** The approval screen showed a vendor name and an amount. It did not show that the bank account had changed days earlier. Approvals came at the agent's pace, so people approved by reflex.
- **No one was watching for the pattern.** The first payment to a new account raised no alert. The loss grew across three invoices before anyone noticed.

None of these gaps is a model failure. That is why model-centered governance would not have caught it.

The ROE-AI approach

ROE-AI governs delegated authority, not the model. Every control asks two questions: what may this agent do on someone's behalf, and who answers for it?

The framework adapts a system the military has refined over generations for exactly this problem. Commanders routinely delegate authority to people who act fast, under pressure, with incomplete information. Rules of engagement, chain of command, and after-action reviews exist so that delegation stays bounded and accountable. AI agents now face the same conditions, and they need the same discipline.

ROE-AI has eight elements, each mapped to a function of the NIST AI Risk Management Framework (Govern, Map, Measure, Manage). That mapping is my own and is still being validated against NIST's official playbook. Its central tool is a three-tier rule set. Every action an agent can take is sorted into **Act** (do it), **Ask** (get human confirmation first), or **Never** (blocked, whatever the instruction).

Applying ROE-AI to the incident

Applied before go-live, ROE-AI is designed to stop this attack at four separate points: Rules of Engagement, Positive Identification, and Need-to-Know each block the bank-detail change on their own, and SITREPs should catch the first payment if all three failed.

Element	What ROE-AI requires	Effect on this incident	NIST AI RMF (proposed)
Commander's Intent	"Pay legitimate vendors accurately and on time." Protecting member funds outranks speed.	Gives the agent a reason to pause on anything unusual	Map
Rules of Engagement	Act: match invoices to POs. Ask: payments over a set threshold. Never: change payee bank details.	**Blocks the bank-detail change outright**	Govern, Manage
Chain of Command	A named owner in finance operations. Bank-detail changes stay with a human, verified by phone.	Removes the authority the attacker needed	Govern
Readiness Certification	Red-team the agent with business email compromise and injected-instruction tests before go-live.	Finds the injection weakness before deployment	Measure
Positive Identification	Email content is information, never orders. Payee changes require an out-of-band callback.	**The hidden text carries no authority**	Manage
OPSEC / Need-to-Know	The agent can read vendor records but cannot write banking fields.	**Even a fooled agent cannot make the change**	Manage

Element	What ROE-AI requires	Effect on this incident	NIST AI RMF (proposed)
SITREPs	Alert on the first payment to any new or changed account.	**Flags the first transfer and caps the loss**	Measure
After-Action Review	Review the human approvals, not just the agent: why did people rubber-stamp?	Fixes the human side of the control	Govern, Manage

The layering matters. No single control has to be perfect, because an attacker has to defeat all of them.

Where the framework strained: meaningful confirmation

This scenario exposed a gap in ROE-AI itself. The Ask tier assumes that a human confirmation is a real check. Here it wasn't. A person approved every fraudulent payment, because the approval screen showed too little and the requests came too fast to think about.

A human in the loop is only a control if the human can actually judge. So I propose an upgrade to ROE-AI that defines what a valid confirmation must show:

1. **What changed.** Any difference from the last time this action was approved, such as a new bank account.
2. **Why it is unusual.** The specific flag that sent the action to the Ask tier.
3. **What happens if approved.** The consequence in plain terms, such as "$160,000 leaves to an account first used today."

Under this proposal, an approval that does not show these three things would not count as an Ask. The upgrade would strengthen the Rules of Engagement element, and it applies well beyond payments: anywhere people approve agent actions in bulk.

Lessons for leaders

Five questions to ask about any AI agent that can act on your organization's behalf:

1. **What can it change, not just what can it read?** Write access is where the risk lives.
2. **What is on its Never list?** If no one can name it, the agent has no hard limits.

3. **Can it tell an order from information?** Emails, documents, and web pages should never carry authority.
4. **What does your approver actually see?** If the screen doesn't show what changed and why it matters, the approval is a formality.
5. **Who answers for it?** Every agent needs a named human owner whose own authority sets its ceiling.

About the author

I served 25 years in the U.S. Army, first as an enlisted Soldier and then as an officer, in roles that included Senior HR Officer, DIA Branch Chief, and service at the U.S. Embassy in Uruguay. Rules of engagement, chain of command, and after-action reviews were part of how that work got done. ROE-AI is my attempt to apply that discipline to AI agents. I hold CompTIA Security+ and am developing ROE-AI as an independent initiative.

ROE-AI is a working framework, not a published standard. I have tested it against four hypothetical scenarios in healthcare, financial services, critical infrastructure, and government, and each test changed the framework. I would welcome critique from practitioners in any of those fields: tomeeka.l.sibley@icloud.com

Sources

- NIST AI Risk Management Framework